

MERIDIAN HEALTH ANALYTICS, INC. — ENTERPRISE

Sample GRC portfolio artifact | Fictional company | Prepared by Chris Morrissey | Review

Risk ID	Date Identified	Risk Category	Risk Description
R-001	2026-01-08	Data Protection	Unencrypted PHI backups stored in legacy on-prem NAS accessible to broader IT staff than required
R-002	2026-01-08	Access Control	Shared service account used by three ETL pipelines with standing admin privileges to production database
R-003	2026-01-15	Third-Party / Vendor	Claims clearinghouse vendor (ClaimLink Corp) has not provided a current SOC 2 Type II report
R-004	2026-01-20	Business Continuity	Single AWS region deployment with no tested failover for claims processing platform
R-005	2026-01-22	Application Security	Customer-facing patient portal has not undergone penetration testing since acquisition of PortalWorks platform
R-006	2026-02-02	Insider Threat	Departed employees' access not consistently deprovisioned within policy SLA (24 hours)
R-007	2026-02-05	Compliance / Regulatory	Business Associate Agreements (BAAs) not on file for 2 of 11 active subcontractors handling PHI
R-008	2026-02-10	Cloud / Infrastructure	Production AWS S3 buckets identified with overly permissive bucket policies during quarterly config review
R-009	2026-02-14	Physical Security	Colocation data center badge access logs not reviewed on a recurring schedule
R-010	2026-02-18	Change Management	Emergency changes to production billing system bypass standard change advisory board (CAB) review
R-011	2026-02-20	Data Protection	Marketing analytics team exports de-identified patient datasets to local laptops for ad-hoc analysis
R-012	2026-02-25	Third-Party / Vendor	Payment processor integration relies on deprecated TLS 1.1 fallback for backward compatibility with one legacy client
R-013	2026-03-01	Human Resources / Security Awareness	Phishing simulation click rate (14%) exceeds industry benchmark and internal target (5%)
R-014	2026-03-05	Application Security	API rate limiting not enforced on provider directory public API, enabling potential scraping/enumeration

R-015	2026-03-10	Business Continuity	Key-person dependency: single engineer holds undocumented knowledge of legacy claims adjudication rules engine
-------	------------	------------------------	---

ISE RISK REGISTER

w cycle: Quarterly

Asset / Process Affected	Threat Source	Vulnerability	Inherent Likelihood (1-5)	Inherent Impact (1-5)
Patient claims data warehouse	External attacker / Malicious insider	Backup volumes not encrypted at rest; excessive access group membership	4	5
Production PHI database	Insider threat / Credential compromise	No individual accountability; standing privileged access; password not rotated	4	5
Eligibility verification workflow	Vendor breach / Supply chain compromise	No independent assurance of vendor control environment in past 18 months	3	4
Claims processing application (us-east-1)	Regional outage / Natural disaster	No multi-region redundancy; DR runbook untested in 14 months	3	5
Patient self-service portal	External attacker	Unknown vulnerability posture on acquired codebase	4	4
All SaaS applications (Okta-federated)	Malicious/negligent former employee	Manual offboarding checklist; no automated SSO deprovisioning trigger	3	4
Vendor management program	Regulatory (HHS OCR)	Contract lifecycle gap; no centralized BAA tracking system	2	5
Data lake / analytics staging	External attacker / Data exposure	Misconfiguration; no automated guardrail preventing public ACLs	3	5
Legacy colocation facility (non-AWS)	Unauthorized physical access	No formal quarterly physical access review process	2	4
Billing and revenue cycle system	Operational error	Emergency change process lacks retrospective review requirement	3	4
Analytics / BI environment	Data loss / Device theft	No DLP controls on endpoint; de-identification method not independently validated	3	3
Payment gateway integration	External attacker (protocol downgrade)	Legacy client dependency delaying TLS 1.1 deprecation	2	4
All employees (email)	External attacker (phishing/BEC)	Insufficient security awareness training cadence; no role-based training for high-risk groups	4	3
Provider directory API (public)	External attacker (data scraping)	No rate limiting or bot detection at API gateway	3	2

Claims adjudication system	Operational / Staffing	No documentation; no cross-training; high attrition risk role	3	4
----------------------------	------------------------	---	---	---

Inherent Risk Score	Inherent Risk Level	Existing Controls	Control Effectiveness (1-5)	Residual Likelihood (1-5)	Residual Impact (1-5)
20	Critical	Encrypted nightly backups migrated to AWS S3 with SSE-KMS; access restricted to 3-person backup admin group	4	2	2
20	Critical	Service account rotated quarterly; database activity logging enabled	3	3	2
12	High	Vendor contract includes data protection addendum; annual security questionnaire on file	2	3	3
15	Critical	Daily automated snapshots; documented (but untested) DR runbook	3	4	3
16	Critical	WAF in front of portal; automated SAST scanning in CI pipeline	3	3	3
12	High	HR ticketing triggers manual IT offboarding task; monthly access audit	3	2	3
10	High	Legal review required before vendor onboarding (policy exists, enforcement inconsistent)	2	2	4
15	Critical	AWS Config rules deployed post-discovery; buckets remediated same day as found	1	4	1
8	Medium	Badge system with logging; visitor escort policy	2	2	3
12	High	Emergency changes logged in ticketing system after the fact	3	2	3
9	Medium	Endpoint encryption (BitLocker/FileVault) enforced via MDM	3	2	2
8	Medium	TLS 1.2+ enforced for 98% of traffic; monitoring on legacy endpoint	2	2	3
12	High	Annual security awareness training; email banner tagging for external senders	3	2	2
6	Medium	API gateway logging enabled; basic authentication required for write operations	2	2	1

12	High	None formal; tribal knowledge only	3	4	3
----	------	------------------------------------	---	---	---

Residual Risk Score	Residual Risk Level	Risk Treatment	Treatment Plan / Next Actions	Risk Owner
4	Low	Mitigate	Complete migration to encrypted cloud backup by Q2; decommission legacy NAS; run access recertification	VP Infrastructure
6	Medium	Mitigate	Migrate ETL to IAM role-based auth (no static creds); implement just-in-time privileged access via PAM tool	Director of Engineering
9	Medium	Mitigate	Escalate to procurement; request updated SOC 2 Type II or bridge letter; evaluate alternate vendor if unresolved by contract renewal	Vendor Risk Manager
12	High	Mitigate	Stand up warm standby in us-west-2; conduct tabletop DR exercise; update BIA recovery time objectives	Director of Infrastructure
9	Medium	Mitigate	Commission third-party penetration test; remediate critical/high findings before next release	AppSec Lead
6	Medium	Mitigate	Automate deprovisioning via Okta Lifecycle Management tied to HRIS termination event	IAM Manager
8	Medium	Mitigate	Build centralized BAA tracker; obtain missing BAAs within 30 days; add BAA checkpoint to procurement workflow	Compliance Officer
4	Low	Mitigate	Enable AWS Config conformance pack + SCP to block public bucket policies account-wide; add to CI/CD pre-deploy checks	Cloud Security Engineer
6	Medium	Accept	Add colo badge log review to quarterly physical security checklist; low residual risk given facility is being decommissioned in migration plan	Facilities / Security Manager
6	Medium	Mitigate	Require mandatory 48-hour post-implementation CAB review for all emergency changes; track in change management KPIs	IT Change Manager
4	Low	Mitigate	Deploy DLP policy restricting bulk export; validate de-identification methodology against Safe Harbor standard; move analysis to governed workspace	Data Governance Lead
6	Medium	Mitigate	Migrate final legacy client to TLS 1.2 by contract deadline; disable TLS 1.1 fallback entirely	Director of Engineering
4	Low	Mitigate	Move to quarterly phishing simulations; targeted training for finance and HR (BEC-high-risk); track click rate as security KPI	Security Awareness Lead
2	Low	Accept	Monitor for abuse patterns; add to backlog for API gateway rate-limiting rollout in Q3	API Platform Lead

12	High	Mitigate	Document rules engine logic and decision tables; cross-train second engineer; add to succession plan	Engineering Manager
----	------	----------	--	---------------------

Target Remediation Date	Status
2026-05-15	In Progress
2026-04-30	In Progress
2026-03-31	Open
2026-06-30	Open
2026-03-15	Open
2026-04-15	In Progress
2026-03-10	Open
2026-02-28	In Progress
2026-05-01	Open
2026-04-01	Open
2026-05-30	Open
2026-06-01	Open
2026-04-30	In Progress
2026-07-31	Open

2026-05-15	Open
------------	------

RISK REGISTER

Risk Scoring

Critical

High

Medium

Low

Likelihood Scale

Impact Scale

Risk Treatment Options

How to use this cells

Review Cadence

! — METHODOLOGY & LEGEND

Risk Score = Likelihood (1-5) x Impact (1-5). Range 1-25.

20-25 — Immediate executive escalation and remediation required

10-19 — Remediation plan required within 30-60 days

5-9 — Remediation plan required within 90 days, or documented risk acceptance

1-4 — Monitor; remediate opportunistically or formally accept

1=Rare, 2=Unlikely, 3=Possible, 4=Likely, 5=Almost Certain

1=Negligible, 2=Minor, 3=Moderate, 4=Major, 5=Severe (regulatory, financial, or patient-safety consequence)

Accept = retain risk within tolerance; Mitigate = reduce likelihood/impact via controls; Transfer = insurance/contract; Avoid = discontinue the activity

Blue-bordered numeric cells (Likelihood/Impact/Effectiveness) are the editable inputs. Risk Score and Risk Level columns are formulas — do not hardcode.

Full register reviewed quarterly by the GRC function; Critical/High risks reviewed monthly by risk owners; register updated continuously as new risks are identified.